Seguridad, Rendimiento y Disponibilidad de Servicios e Infraestructuras

Ana I. González Acuña

Grado en Ingeniería Informática



2026/27

SRDSI

1. Introducción a la seguridad informática
2. Seguridad en la comunicación
3. Seguridad en los servicios
4. Seguridad Operacional



Tema 1: Introducción a la seguridad informática



1 Introducción a la seguridad informática
1.1 Conceptos básicos de seguridad informática
1.2 Introducción a la criptografía
1.3 Características comunicación segura
1.4 Gestión de claves.



1 Introducción a la seguridad informática
1.1 Conceptos básicos de seguridad informática
- Visión global
- Elementos a proteger
- Servicios de seguridad
- Amenazas y ataques
- Mecanismos de seguridad

1.2 Introducción a la criptografía
1.3 Características comunicación segura
1.4 Gestión de claves.



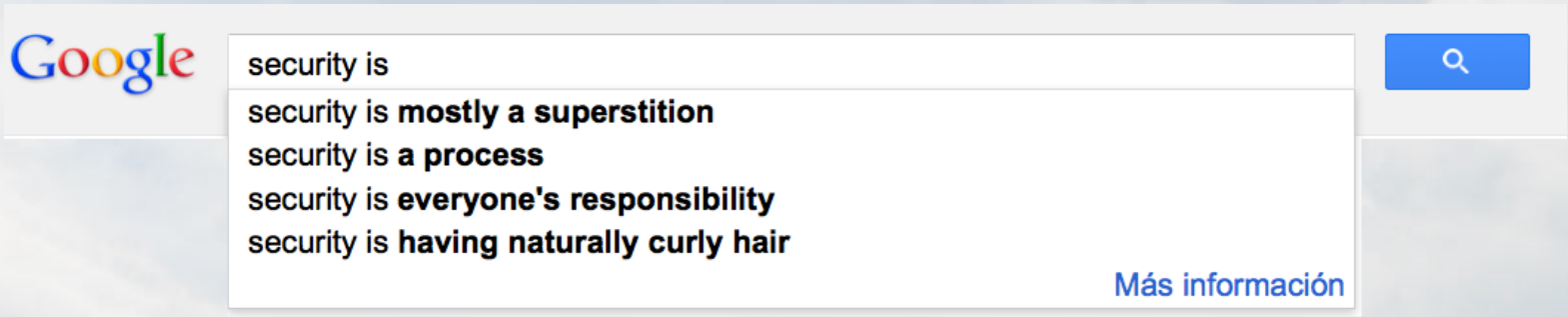
"El único sistema que es totalmente seguro es aquel que se encuentra apagado y desconectado, guardado en una caja fuerte de titanio que está enterrada en cemento, rodeada de gas nervioso y de un grupo de guardias fuertemente armados. Aún así, no apostaría mi vida en ello" – E.H. Spafford



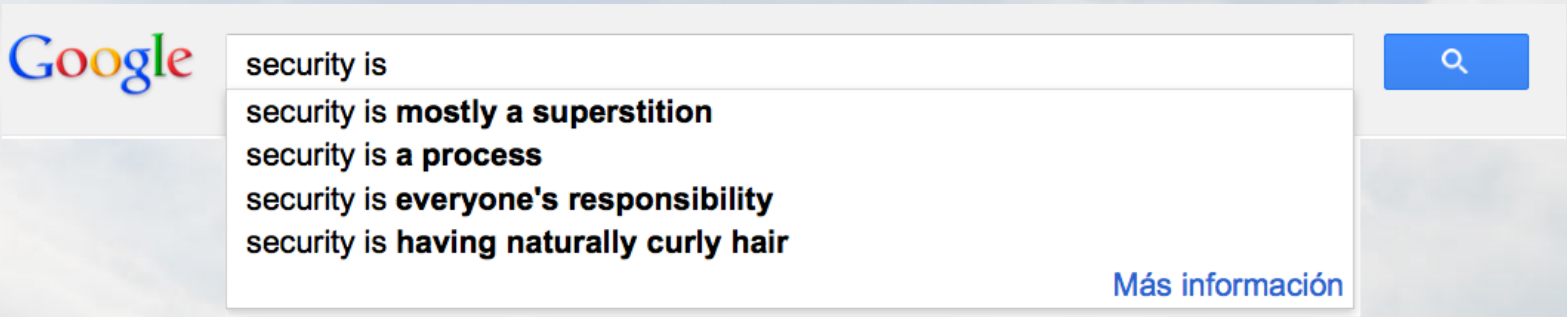
¿Qué es seguridad?



¿Qué es seguridad?



¿Qué es seguridad?





El término **seguridad** proviene de la palabra *securitas* del latín.[1] Cotidianamente se puede referir a la seguridad como la ausencia de riesgo o también a la confianza en algo o alguien. Sin embargo, el término puede tomar diversos sentidos según el área o campo a la que haga referencia.



Seguridad informática (*Information Technology Security*)

Computer Security: The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications).

NIST Computer Security Handbook



Seguridad informática (*Information Technology Security*)

Computer Security: The protection afforded to an automated information system in order to attain the applicable objectives of preserving the integrity, availability and confidentiality of information system resources (includes hardware, software, firmware, information/data, and telecommunications).

NIST Computer Security Handbook

```
$ computer security (COMPUSEC)
   (I) Measures that implement and assure security services in a
   computer system, particularly those that assure access control
   service.

   (C) Usually understood to include functions, features, and
   technical characteristics of computer hardware and software,
   especially operating systems.
```

RFC 2828



```
$ communication security (COMSEC)
```

(I) Measures that implement and assure security services in a communication system, particularly those that provide data confidentiality and data integrity and that authenticate communicating entities.

(C) Usually understood to include cryptographic algorithms and key management methods and processes, devices that implement them, and the life cycle management of keying material and devices.

RFC 2828



```
$ communication security (COMSEC)
   (I) Measures that implement and assure security services in a
   communication system, particularly those that provide data
   confidentiality and data integrity and that authenticate
   communicating entities.

   (C) Usually understood to include cryptographic algorithms and key
   management methods and processes, devices that implement them, and
   the life cycle management of keying material and devices.
```

RFC 2828

La **seguridad informática** es el **conjunto de técnicas, normas y herramientas diseñadas para proteger los sistemas, redes, dispositivos y datos frente a daños, robos o accesos no autorizados**. Wikipedia +2

Gemini: ¿qué es la seguridad informática?



Seguridad de la información

Information security, or InfoSec, includes the tools and processes for preventing, detecting, and remediating attacks and threats to sensitive information, both digital and non-digital. InfoSec is also concerned with documenting the processes, threats, and systems that affect the security of information.

Fortinet cyberglossary



Seguridad de la información

Information security, or InfoSec, includes the tools and processes for preventing, detecting, and remediating attacks and threats to sensitive information, both digital and non-digital. InfoSec is also concerned with documenting the processes, threats, and systems that affect the security of information.

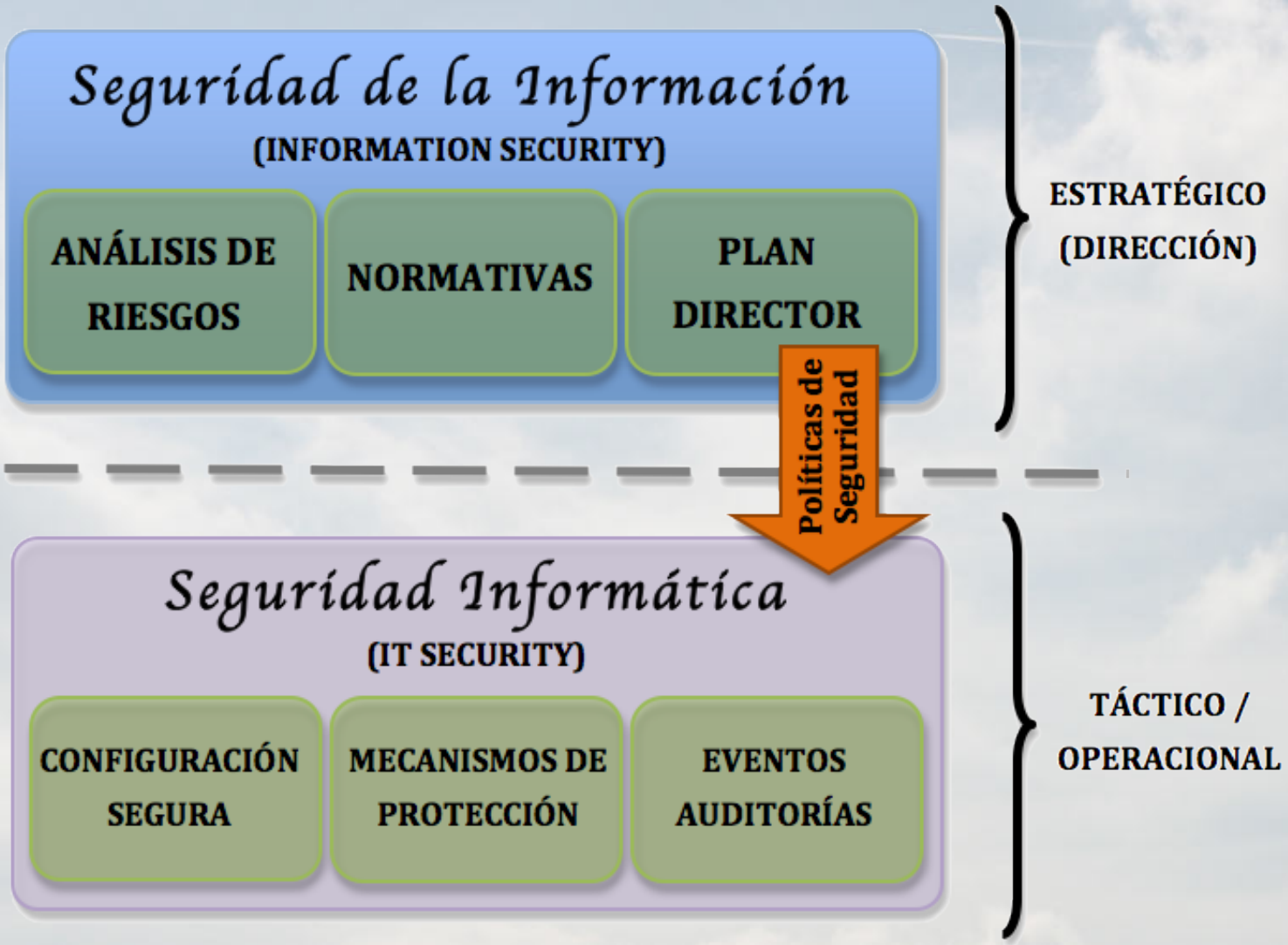
Fortinet cyberglossary

"Information Security is a multidisciplinary area of study and professional activity which is concerned with the development and implementation of security mechanisms of all available types (technical, organisational, human-oriented and legal) in order to keep information in all its locations (within and outside the organisation's perimeter) and, consequently, information systems, where information is created, processed, stored, transmitted and destroyed, free from threats. Threats to information and information systems may be categorised and a corresponding security goal may be defined for each category of threats. A set of security goals, identified as a result of a threat analysis, should be revised periodically to ensure its adequacy and conformance with the evolving environment. The currently relevant set of security goals may include: *confidentiality,* integrity, availability, privacy, authenticity & trustworthiness, non-repudiation, accountability and auditability."

"**Information Security** and Information Assurance: **Discussion about the Meaning**, Scope, and Goals." Cherdantseva, Y. and Hilton, J. *Organizational, Legal, and Technological Dimensions of Information System Administration.* IGI Global, **2014**. 167-198. Web. 4 Jun. 2014. doi:10.4018/978-1-4666-4526-4.ch010



Seguridad Informática vs Seguridad de la información



¿Qué hacer? Gestión de la seguridad

Fundamental: Proteger la información y los sistemas de información

Gestión **de riesgos de seguridad** : Realizar un análisis de las amenazas potenciales que puede sufrir un sistema, las pérdidas que podrían generar y la probabilidad de su ocurrencia, coste del ataque y de las posibles contramedidas.

Política **de seguridad:** Conjunto de normas que describen con precisión qué acciones le están autorizadas a las entidades de un sistema y cuáles están prohibidas, que permitan prevenir, identificar y reaccionar ante posibles ataques.

Mecanismos **de seguridad**: Aquellos mecanismos utilizados para garantizar la correcta implantación de la política de seguridad.



O sentarnos a esperar ;-)

- Juan Ignacio Cirac (2014)
- Así cambiará el mundo la computación cuántica: Ignacio Cirac (2018)
- Juan Ignacio Cirac: "Estamos ya inmersos en la Segunda Revolución Cuántica" (2023)
- The wild project #353 (2025)



... no habrá que esperar mucho,

Ordenador cuántico 20 qubits

CES ›

IBM presenta el primer ordenador cuántico comercial

La compañía cree que este es el primer paso para el despegue de esta tecnología más allá de los laboratorios

PATRICIA FERNÁNDEZ DE LIS
Las Vegas - 10 ENE 2019 - 19:43 CET



IBM ha anunciado en CES (la feria de tecnología de consumo más importante del mundo, que se celebra esta semana en Las Vegas) el primer ordenador cuántico para uso comercial, Q System One, del que Wisneiff es su principal responsable técnico. IBM describe su máquina como "el primer sistema de computación cuántica universal diseñado para el uso científico y comercial". La máquina, de 20 cubits (bits cuánticos), ha sido diseñada para impresionar. Está metida en una urna de cristal que absorbe el sonido y las vibraciones, y mantiene la temperatura estable, ya que los chips cuánticos son extremadamente delicados. El diseño ha sido realizado por la famosa compañía de diseño industrial Map Project Office, que le ha dado una imagen entre *vintage* (es, claramente, un ordenador) y futurista. Sin embargo, y aunque la compañía hable del uso comercial del Q System One, a esta tecnología aún le queda mucho para ser utilizada fuera del circuito de la investigación científica.

https://elpais.com/tecnologia/2019/01/10/actualidad/1547082206_169717.html



... los tenemos muy cerca,

El Gobierno Vasco e IBM inauguran en Donostia el primer IBM Quantum System Two de Europa

Oct 14, 2025



Esta instalación de IBM Quantum System Two es solo la segunda de este tipo fuera de los Estados Unidos. Está equipada con un procesador IBM Quantum Heron de 156 qubits, uno de los procesadores cuánticos con mejor rendimiento desarrollados por la empresa hasta la fecha. Diseñado para escalar e integrar varios procesadores en el futuro, este sistema marca un hito tecnológico, ya que permite ejecutar algoritmos de escala de uso, superando las capacidades de simulación clásica.

https://www.basquequantum.eus/es



San Sebastián tendrá uno de los ordenadores cuánticos más potentes del mundo (Jn25)

... ¿ y en casa?

Ya puedes comprarte el primer ordenador cuántico portátil de la historia: solo te costará 8000 euros

22/05/2023 10:00

De acuerdo con News.am, el primer sistema cuenta con 2-qubit y desembarcó primero en las instituciones educativas de China, Taiwán y Canadá, dónde los estudiantes podrán aprender los principios de la programación en sistemas cuánticos de estos dispositivos. Ahora cualquiera que tenga los 8.700 dólares que cuesta podrá pagarlo, aunque no es algo que cualquiera pueda utilizar, ya que no es especialmente sencillo.

El más barato de todos cuenta con un peso **ni más ni menos de 14KG** y cuenta con el software "CASTOR" para poder simular operaciones de hasta 8 qubits. El siguiente en la escala es el "Gemini", que también da un grandísimo salto en el precio y alcanza los 39.000 euros aunque no se sabe realmente por qué, ya que cuenta con exactamente **la misma potencia que su predecesor**.

Finalmente, el modelo "Triangulum" es el último de esta triada de ordenadores personales y cuenta con **3 qubit de potencia**. Lleva incorporado el software "SpinQuasar" y pesa **más de 40 kilogramos**. Así, aunque sean personales de portátiles tienen bastante poco.

Primer ordenador cuántico portátil



...

Gemini Mini is a conditionally portable, entry-level 2-cubit system (27 ± 1.5 MHz (H) and 11 ± 0.5 MHz (P) qubit frequencies) equipped with a touch screen. The coherence hold time is >20ms. The device weighs 14 kilograms with dimensions of 200 × 350 × 260 mm and costs, as noted, about $8,700. The device has built-in CASTOR software, allowing it to simulate the operation of 8 qubits.



Portable Quatum Computerspinq

Hacia el internet cuántico...

Futuro de las redes: comunicacion cuántica

Cómo funciona el cable cuántico ultraseguro que están usando bancos y grandes empresas para proteger sus secretos

Redacción
BBC News Mundo

https://www.bbc.com/mundo/noticias-46877277

15 enero 2019

Compartir

El túnel Holland, que conecta la isla de Manhattan, en Nueva York, con el estado de Nueva Jersey, es el más antiguo de los destinados al tráfico de vehículos en Estados Unidos.

En ese túnel se ocultan unos cables de fibra óptica hechos con mecánica cuántica que tienen la capacidad de proteger datos críticos de bancos y agencias gubernamentales. Y ya están siendo probados.
Se trata de una tecnología llamada sistema de **distribución de claves cuánticas (QKD)** que permite generar e intercambiar **claves secretas** usando dos fotones entrelazados que solo conocen emisor y receptor.

Y lo más interesante es que esas claves no pueden ser copiadas.

Funciona a través de lo que muchos consideran el futuro de las comunicaciones: la **mecánica cuántica**.



...

Por primera vez consiguen "teletransportar" información entre dos chips sin estar conectados física o electrónicamente, según la Universidad de Bristol

RAÚL ÁLVAREZ 27 Diciembre 2019

Científicos de la Universidad de Bristol y de la Universidad Técnica de Dinamarca están publicando los resultados de una nueva e interesante investigación, donde afirman haber logrado por primera vez **la "teletransportación cuántica" entre dos chips de ordenador.**

Según los responsables de esta hazaña, consiguieron **enviar información de un chip a otro de forma instantánea**, esto sin que los chips tuvieran algún tipo de conexión física o electrónica. En caso de que se confirme este logro, se abriría la puerta al llamado "internet cuántico".

Cabe señalar que previamente, en investigaciones y experimentos anteriores, se había conseguido "teletransportación cuántica" a grandes distancias, pero entre diferentes componentes de un solo chip. Sin embargo, esta es **la primera vez en la historia que se logra realizarlo entre dos chips diferentes**, lo que significa un gran avance para la computación cuántica.

https://www.nature.com/articles/s41567-019-0727-x

https://www.xataka.com/investigacion/primera-vez-consiguen-teletransportar-informacion-dos-chips-estar-conectados-fisica-electronicamente-universidad-bristol



Con otros objetivos ...

NSA seeks to build quantum computer that could crack most types of encryption

By Steven Rich and Barton Gellman, Published: January 2 **E-mail the writers**

In room-size metal boxes secure against electromagnetic leaks, the National Security Agency is racing to build a computer that could break nearly every kind of encryption used to protect banking, medical, business and government records around the world.

According to documents provided by former NSA contractor Edward Snowden, the effort to build "a cryptologically useful quantum computer" — a machine exponentially faster than classical computers — is part of a $79.7 million research program titled "Penetrating Hard Targets." Much of the work is hosted under classified contracts at a laboratory in College Park, Md.

Computación cuántica contada en dos minutos (2024)
Algoritmo-factorizacion



...



RSA, pilar de muchas seguridades digitales, se basa en una doble clave para cifrar y descifrar la información. Su robustez ha aparecido durante mucho tiempo como indestructible para las computadoras clásicas, que necesitarían millones de años para romper los sistemas más simples.

El cifrado RSA se basa en un problema matemático extremadamente complejo: la factorización de grandes números en números primos. Este problema es fácil de resolver si se conoce la clave privada, pero extremadamente difícil sin ella. Sin embargo, investigadores chinos afirman haber logrado romper un RSA de 50 bits, una versión simplificada de este cifrado, utilizando qubits en un calculador cuántico de D-Wave. Emplearon una técnica de "recocido cuántico", capaz de evaluar varias soluciones simultáneamente, acelerando así la resolución.

No obstante, el cifrado RSA utilizado en la mayoría de las comunicaciones modernas es infinitamente más complejo. Las claves comunes de 1024 a 2048 bits requerirían una potencia de cálculo cuántico aún fuera del alcance de las tecnologías actuales.



... aunque no siempre son necesarios

RSA "roto" por su creador

SEGURIDAD

Uno de los cifrados más seguros, roto por su propio creador

Tres investigadores, entre ellos el coautor del mismo, descubren la manera de deducir la clave criptográfica de los sonidos que emite el procesador del ordenador

19.12.13 - 19:08 - INNOVA+ | MADRID

Está considerado uno de los métodos de cifrado más seguros que existen. RSA-4096 es el estándar de facto para **compartir información de forma confidencial en un medio inseguro**. Pero un grupo de investigadores, entre los que está uno de sus creadores originales, ha encontrado una técnica poco convencional de romperlo mediante 'criptoanálisis acústico'. Es decir, interpretando los sonidos que genera uno de los ordenadores implicados en la comunicación privada.

Adi Shamir (su apellido pone la 'S' en RSA) y otros dos investigadores israelís han estudiado los sonidos que emiten los procesadores de algunos ordenadores portátiles cuando están cifrando o descifrando una información. Y han encontrado una serie de patrones que les permite encontrar, en aproximadamente una hora, la clave de criptográfica que utiliza. Es decir, deducen el código que permite convertir una serie de mensajes ininteligibles en datos en limpio.



...

1 ACTUALIDAD · AMENAZAS · HACKING

Investigadores rompen con éxito el cifrado RSA de 1024-bit de GnuPG

por Eduardo Medina 5 de julio, 2017

Una vulnerabilidad hallada en la librería criptográfica **GnuPG** ha permitido a unos investigadores **romper con éxito el cifrado RSA de 1024-bit**, pudiendo de esta manera descifrar los datos cifrados con este algoritmo.

La vulnerabilidad, que tiene como código CVE-2017-7526, reside en la manera en que GnuPG **usa la librería libgcrypt, dejando la puerta abierta a un ataque de flush+reload** (limpieza y recarga de memoria). Investigadores de la Universidad Técnica de Eindhoven (Países Bajos), la Universidad de Illinois, la Universidad de Pensilvania, la Universidad de Maryland (estas tres de Estados Unidos) y la Universidad de Adelaida (Australia) han encontrado que el método de "deslizado de ventana de izquierda a derecha" utilizado por libgcrypt para llevar a cabo las operaciones matemáticas de criptografía filtra más información de lo que debería, mostrando más bits además de los utilizados para el deslizado de izquierda a derecha, abriendo así la puerta a la **recuperación total de la clave RSA**.

https://www.muyseguridad.net/2017/07/05/rompen-rsa-1024-bit-gnupg/



... pero llegará el Q-Day

- Es un **hito criptográfico**: marca el momento en que las computadoras cuánticas puedan romper el cifrado de clave pública utilizado para proteger las comunicaciones, identidades y transacciones digitales.
- **No** se espera **mañana**: la mayoría de los expertos estiman que las computadoras cuánticas relevantes para la criptografía llegarán en la década de 2030 o más tarde, aunque los plazos varían.
- El **riesgo comienza antes**: los ataques de "recopilación ahora, descifrado después" permiten a los atacantes obtener datos cifrados ahora y descifrarlos en el futuro.
- La **criptografía de clave pública** es la más **vulnerable**: RSA, la criptografía de curva elíptica, la infraestructura de clave pública, los certificados y las firmas digitales se enfrentan al mayor riesgo cuántico.



... y hay que prepararse

Polinomios contra ordenadores cuánticos

El proceso de estandarización se completará a partir de 2025 y se comenzará una migración a los nuevos sistemas criptográficos

IGNACIO LUENGO

25 MAY 2018 - 10:48 CEST

Gobiernos y multinacionales están invirtiendo grandes cantidades de dinero en la construcción del ordenador cuántico; a día de hoy IBM y Google son los más avanzados en esta dirección. Estos ordenadores podrán realizar simulación cuántica para modelar complejas reacciones químicas, o diseñar nuevos medicamentos, operaciones que están fuera del alcance de los más potentes ordenadores binarios. Pero este avance también tiene sus inconvenientes, por ejemplo, dejarán de ser seguros los sistemas criptográficos empleados hoy en día para garantizar el comercio electrónico y las comunicaciones en la red, ya que un ordenador cuántico podrá factorizar rápidamente los grandes números en los que se basa la seguridad de algoritmos de cifrado de clave pública o firma digital más empleados, como el RSA y DSA, empleando el algoritmo de Shor.

Frente a esta situación, en 2015 la Agencia Nacional de Seguridad (NSA) de EE UU anunció que los estándares actuales de criptografía de clave pública no son seguros a largo plazo y pidió que se iniciara cuanto antes la búsqueda de algoritmos de cifrado de clave pública seguros contra ordenadores cuánticos, también llamados *postcuánticos*. Motivado por este

cada tecnología en concurso). Según los planes del NIST, el proceso de estandarización se completará a partir de 2025 y se comenzará una migración a los nuevos sistemas criptográficos, preparados para la revolución cuántica. Aunque no se sabe cuándo llegarán los ordenadores cuánticos, todos los datos confidenciales y el tráfico de Internet deberían de estar protegidos a partir de esa fecha, preparados para resistir al futuro cuántico.

https://elpais.com/elpais/2018/05/18/ciencia/1526642306_475745.html



NIST Releases First 3 Finalized Post-Quantum Encryption Standards

August 13, 2024



- NIST has released a final set of encryption tools designed to withstand the attack of a quantum computer.
- These post-quantum encryption standards secure a wide range of electronic information, from confidential email messages to e-commerce transactions that propel the modern economy.
- NIST is encouraging computer system administrators to begin transitioning to the new standards as soon as possible.

NIST: Post quantum encryption standards
RFC 9958: Post-Quantum Cryptography for Engineers
EuroQCI



Tampoco podemos olvidarnos de la ...

Inteligencia Artificial

- **PROS**:
  - Preveer y/o bloquear ataques en tiempo real: analiza millones de datos por segundo para encontrar patrones extraños y frenar ataques antes de que dañen la red.
  - Automatizar tareas rutinarias: parches, clasificar alertas ...
  - Verificación biométrica más precisa y monitorear accesos
  - ...
- **CONTRAS**:
  - Permite el diseño de mensajes de *phishing* más creibles, uso de *deepfakes* (video, audio...)
  - Automatizar ataques, con la búsqueda de vulnerabilidades a explotar en el objetivo
  - Diseño de *malware* de difícil detección
  - ...

Red Seguridad #105

Visión global



Adaptación: "Seguridad en Unix y Redes" Villalón-2002



Amenaza(*threat*) Cualquier **potencial** violación de la seguridad aprovechando la existencia de una **vulnerabilidad** (debilidad en el diseño, implementación o gestión). **Riesgo** es la probabilidad de que una amenaza se materialice y sus consecuencias negativas (pérdidas o daños). Un **incidente** / **ataque** (intencionado) es la realización de una amenaza.

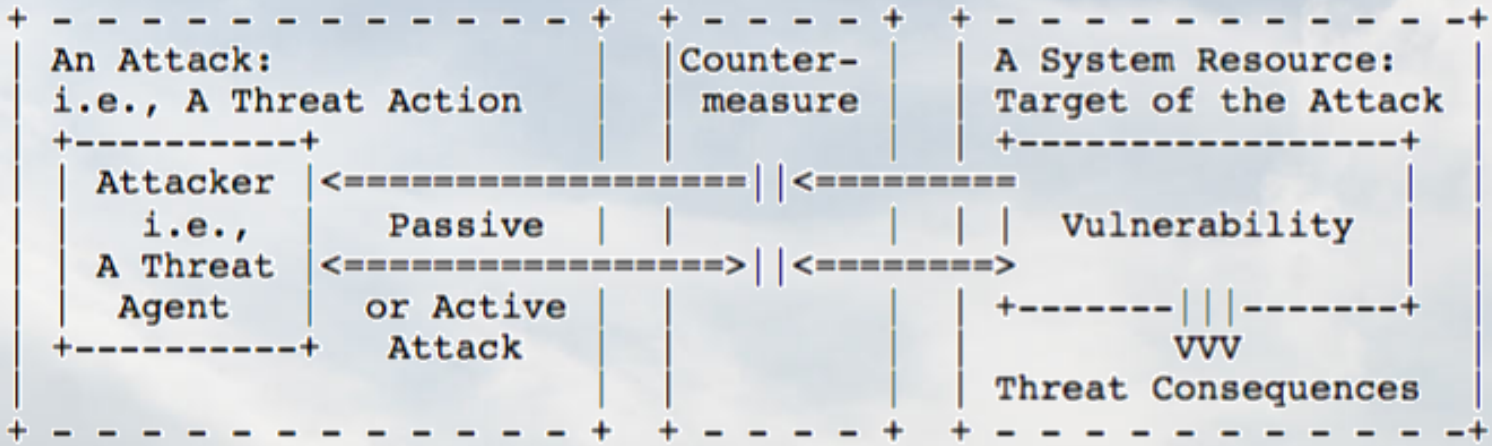
Mecanismo **de seguridad**. Un mecanismo diseñado para prevenir, detectar o reestablecerse de un ataque/daño.

Servicio **de seguridad**: Servicio que está diseñado para mejorar la seguridad, haciendo uso de uno o más mecanismos de seguridad.

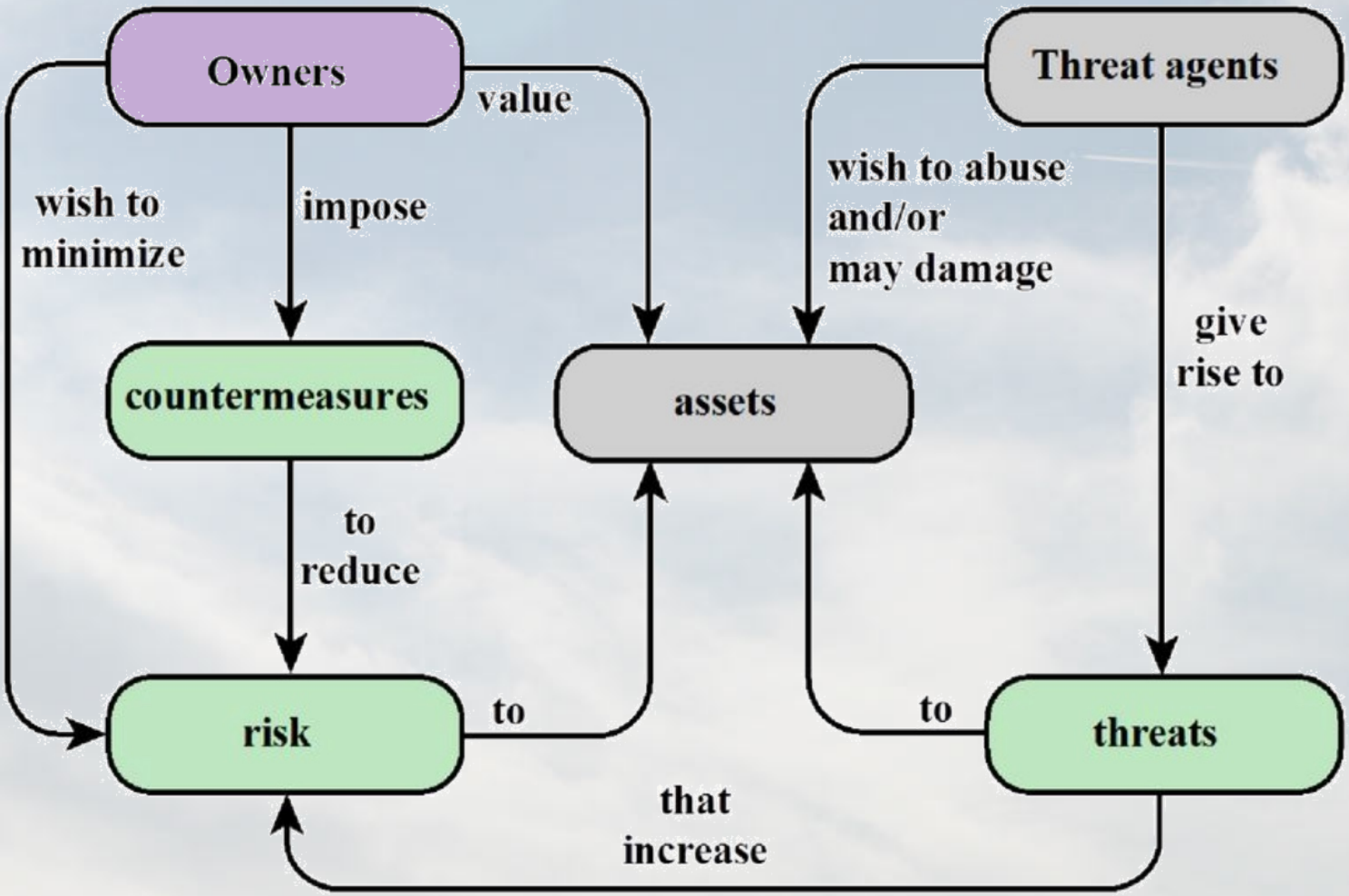
Protocolo **de seguridad**. Conjunto de normas que rigen la comunicación entre dos (o más) entidades del mismo nivel, con el objetivo de prestar determinados servicios de seguridad a las entidades inmediatamente superiores.



Relación entre términos:



$ attack, RFC 4949



©Willian Stallings & Lawrie Brown, Computer Security

Elementos a proteger

Hardware Conjunto formado por todos los elementos físicos de un sistema informático: procesamiento de datos, almacenamiento de datos, y dispositivos de comunicación de datos.

Software Conjunto de programas lógicos que hacen funcionar al hardware, tanto sistemas operativos, como utilidades del sistema y aplicaciones.

Datos Conjunto de información lógica que manejan el software y el hardware: ficheros, bases de datos, contraseñas o información que circula por un medio de transmisión.

Otros: reputación de la entidad, fungibles, infraestructuras...



Servicios (básicos) de seguridad

- Confidencialidad
  Proporciona protección para evitar que la información, almacenada o que circule por una red, sea revelada, accidental o deliberadamente, a una entidad (usuario, proceso o sistema) no autorizada.
- Integridad
  Garantiza que la información no ha sido alterada, duplicada o destruida de una manera no autorizada o debido a un error.
- Autenticación
  Permite verificar la identidad de las entidades y el origen de la información.
- No repudio
  Evitar que cualquier entidad participe niegue haber tomado parte .



...

- Control de acceso
  Prevención del acceso a un recurso y su uso no autorizado.
- Disponibilidad
  Propiedad de ser accesible y utilizable a petición de una entidad autorizada.
- *Anonimato*
  Conseguir que la identidad de las entidades en una comunicación permanezca oculta.
- *Privacidad*
  Conseguir que la actividad de las entidades en una comunicación permanezca oculta.



Amenazas, según procedencia

- Provocadas por personas:
  - Internas: propio personal (intencionado o no)
  - Externas: *"Hacker"*, *cracker*, *lammer* ...
- Lógicas
  - Software malicioso (*malware*, *spyware*...)
  - Herramientas administrativas
  - Errores de configuración o programación (*bugs* + *exploits*)
- Físicas y ambientales
  - Robos, sabotajes
  - Cortes o cambios bruscos del suministro eléctrico
  - Catástrofes naturales o artificiales
  - Interferencias electromagnéticas
  - Fallos/deficiencias del hardware



Amenazas según consecuencias: ataques

Threat consequence: una violación de seguridad que resulta de la materialización de la amenaza (ataque/incidente)

Unauthorized Disclosure	Deception	Disruption	Usurpation
• Exposure • Interception • Inference • Intrusion	• Masquerade • Falsification • Repudiation	• Incapacitation • Corruption • Obstruction	• Misappropriation • Misuses

RFC 4949



Divulgación no autorizada *(Unauthorized disclosure)*

Una entidad no autorizada (persona, programa o equipo) obtiene acceso a un recurso al que no está autorizado

Ejemplos de ataques que la causan:

- *Exposición (Exposure)*
  - Errores humanos, software y hardware
- *Interceptación (Interception)*
  - Pinchar una línea (*wiretapping*)
- *Inferencia (Inference)*
  - Lectura de las cabeceras de paquetes (*traffic analysis*) para desvelar la identidad de uno o más de los usuarios implicados en la comunicación observada ilegalmente
- *Intrusión (Intrusion)*
  - Ingeniería inversa, criptoanálisis



Interrupción *(Disruption)*

Un recurso del sistema es destruido, queda inutilizable o no disponible.

Ejemplos de ataques:

- *Incapacitación*
  - Destrucción de un elemento hardware
  - Malware
  - Desastre natural
- *Corrupción*
  - Errores humanos, software o hardware
- *Obstrucción*
  - Cortar una línea de comunicación
  - DoS, *Flooding*



Engaño *(Deception)*

Una entidad autorizada recibe información falsa que cree cierta.

Ejemplos de ataques que lo pueden causar:

- *Enmascaramiento (Masquerade)*
  - Alterar un programa para que funcione de forma diferente (*Trojan*)
- *Falsificación*
  - Cambio de valores en un archivo o base de datos
  - Modificar el contenido de mensajes que están siendo transferidos por la red (*active wiretapping*)
- *Repudio*
  - Usuario niega haber enviado la información, haberla recibido o disponer de ella



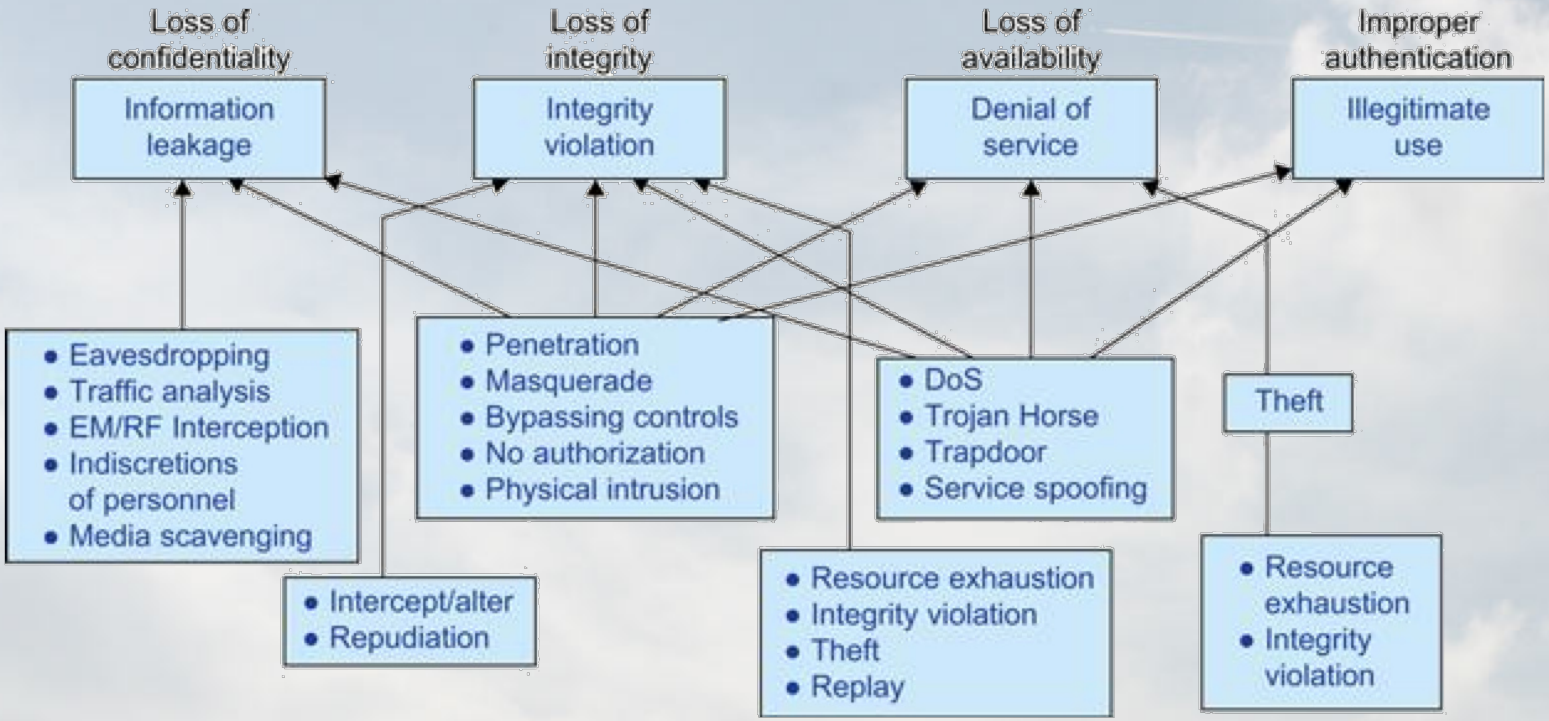
Usurpación *(Usurpation)*

Una entidad no autorizada toma el control de los servicios y funciones del sistema

Ejemplos de ataques:

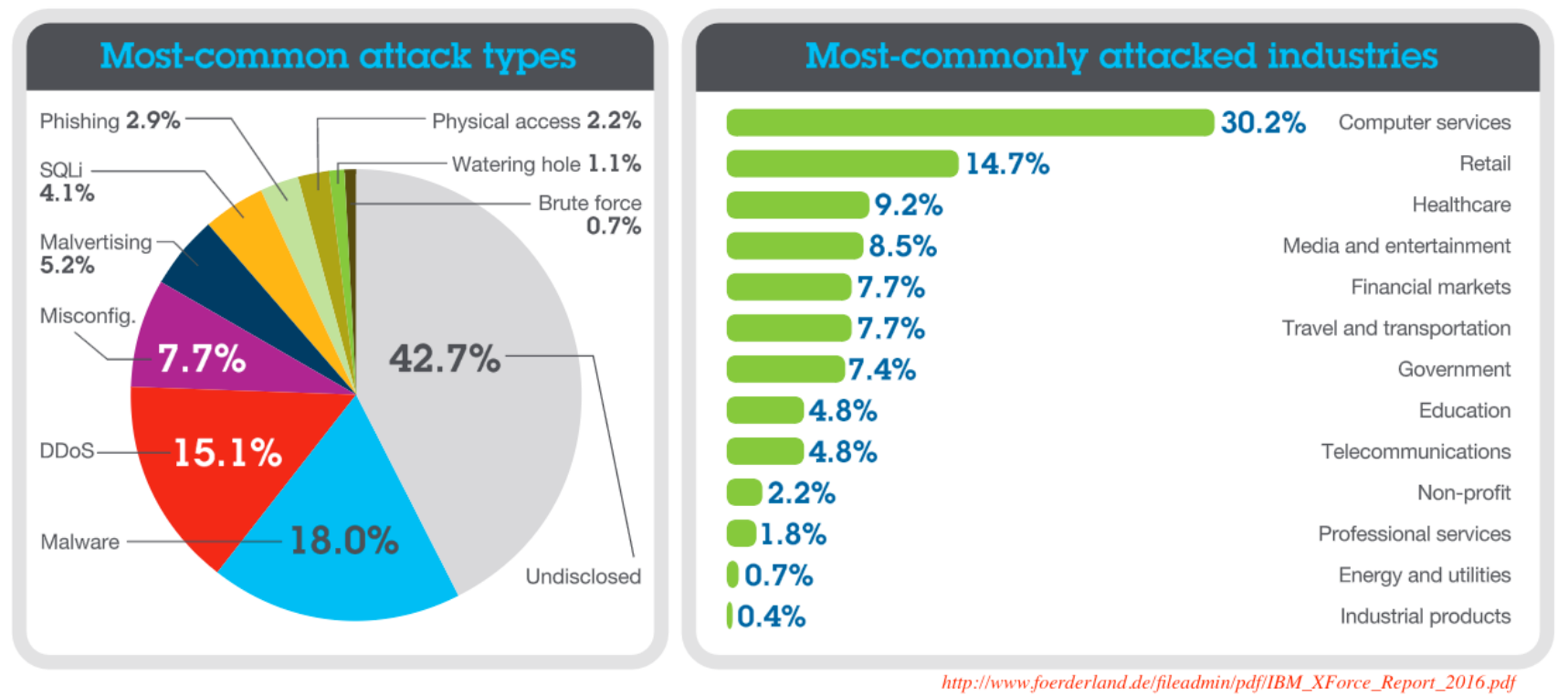
- Apropiación indebida *(Misappropriation)*
  - Utilizar el sistema para realizar un ataque de DDoS a otro sistema (*botnet*).
- Uso indebido *(Misuse)*
  - Escalado de privilegios de usuario





fuente: Distributed and Cloud Computing. K.Hwang. 2012 (googlebooks)

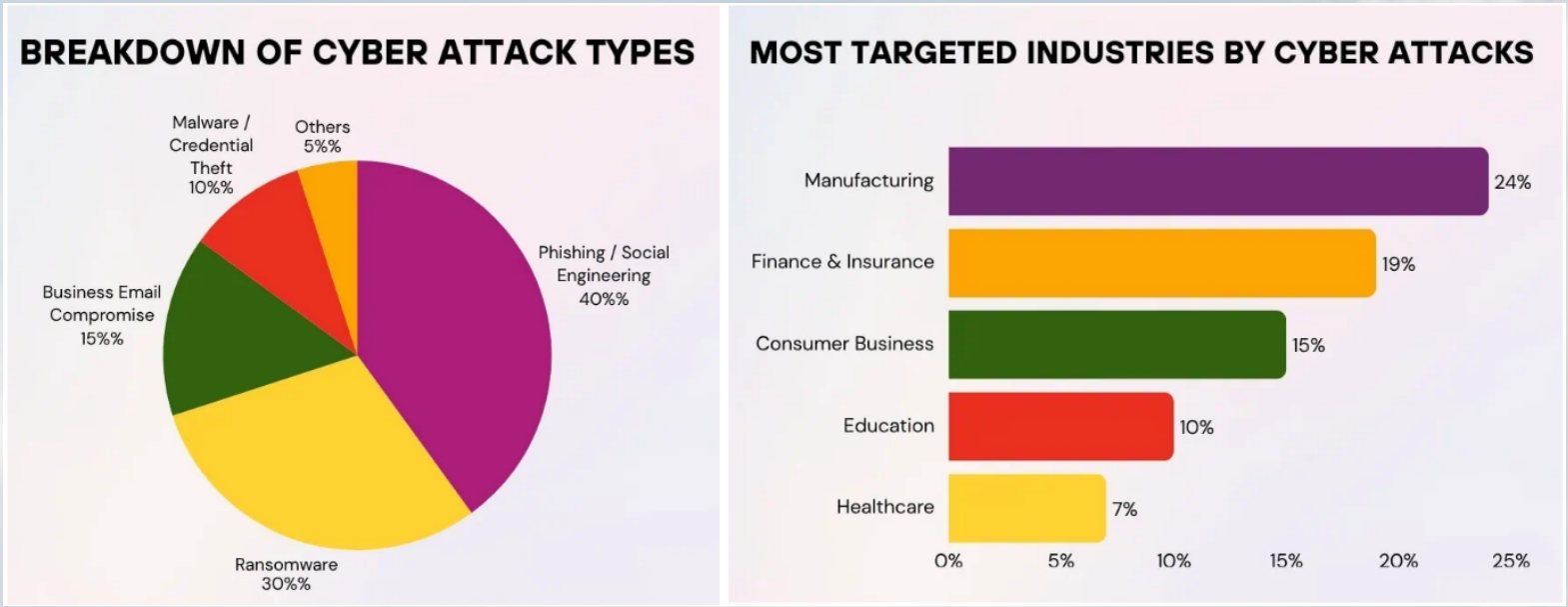




Fuente: https://www.ibm.com/es-es/reports/threat-intelligence

https://informationisbeautiful.net/visualizations/worlds-biggest-data-breaches-hacks/





Fuente:https://sqmagazine.co.uk/cybersecurity-attacks-statistics/ (April 1, 2026)



ACTIVIDAD: *Identificar Amenazas*

Durante la fase de diseño de un servicio seguro, se crea un MODELO DE AMENAZAS, que incluye una lista con las vulnerabilidades del sistema, que permite estimar que riesgo suponen y decidir las contramedidas apropiadas a implantar. El primer paso en este proceso de modelado de amenazas es, por tanto, identificar las amenazas que puede sufrir el servicio.

Actividad:

1. Escoger una categoría (C). Seleccionar cuatros patrones de ataques estándar (S) que pertenezcan al menos a dos metacategorias distintas (M).
2. Realizar una presentación donde se muestren en qué consisten, relaciones, requisitos, consecuencias y prevención de estos ataques.
3. Buscar una noticia que recoja uno de esos ataques.

Common **A**ttack **P**attern **E**numeration and **C**lassification (CAPEC):

- *Domains of attack:*
  https://capec.mitre.org/data/definitions/3000.html



Mecanismos de seguridad

Un mecanismo diseñado para prevenir, detectar o reaccionar/recuperarse de un ataque o incidente



Un mecanismo de seguridad puede servir para implementar uno o varios servicios de seguridad, al igual que un servicio de seguridad puede ser implementado mediante varios mecanismos de seguridad.

Según el recurso a proteger

- **Seguridad física:**
  Protección del hardware (y de su emplazamiento)
  - Estudio de la ubicación y acondicionamiento físico
  - Medidas de prevención contra robos, incendios o inundaciones
  - Control de acceso físico
  - Sistemas de alimentación ininterrumpida (UPS)



- **Seguridad lógica:**
  Protección del software y de los **datos**.
  - Copias de seguridad (*backups*)
  - Control de Acceso Lógico: gestión de contraseñas y permisos de acceso (ACL)
  - Cifrado de comunicaciones y datos
  - Software *antimalware*
  - Actualización del software
  - Filtrado del tráfico
  - Monitorización y análisis del tráfico
  - Integridad del sistema de ficheros
  - ...



Según su puesta en marcha

- **Seguridad activa / proactiva:**
  Prevenir y evitar (grandes) daños en los sistemas informáticos, por tanto se consideran acciones **previas** a un ataque o incidente.
  Medidas de prevención:
  - Todas las medidas de seguridad lógica.
  - Medidas de seguridad física preventivas.



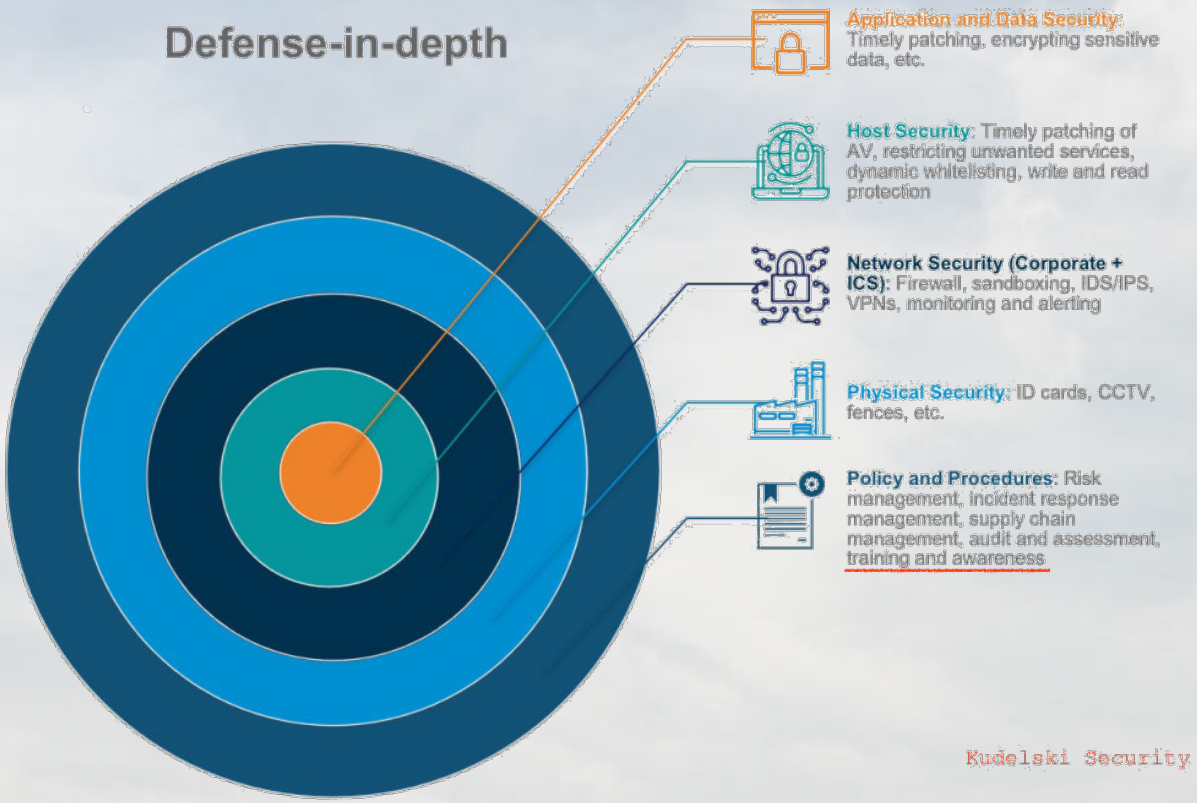
- **Seguridad pasiva / reactiva:**
  Detectar, corregir y minimizar el impacto y efectos **posteriores** a un ataque o incidente.
  Medidas de detección:
  - Medidas de seguridad física y ambientales
  - Análisis de registros (Logs)
  - Checksum
  - Intrusion detection system (IDS)

  Medidas de reacción / recuperación:
  - Copias de seguridad (*Backups*)
  - Hardware/Software redundante
  - Mecanismos de análisis forense, averiguar el alcance del ataque
  - Informes a las partes implicadas y a las autoridades
  - Seguros

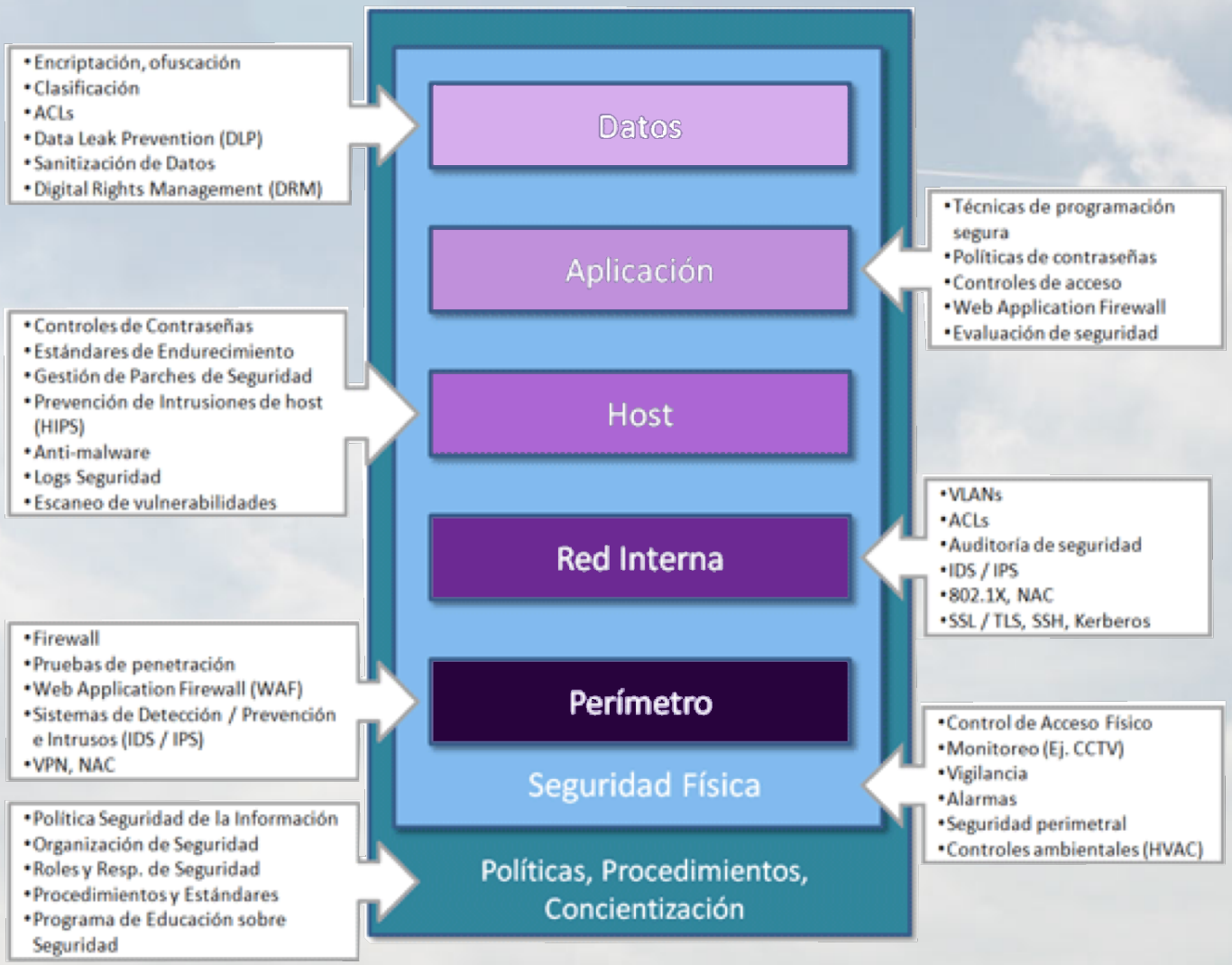


Modelos de seguridad

(Tradicional) **Defensa en profundidad** (*Defense in Depth*) o *Perimeter model*



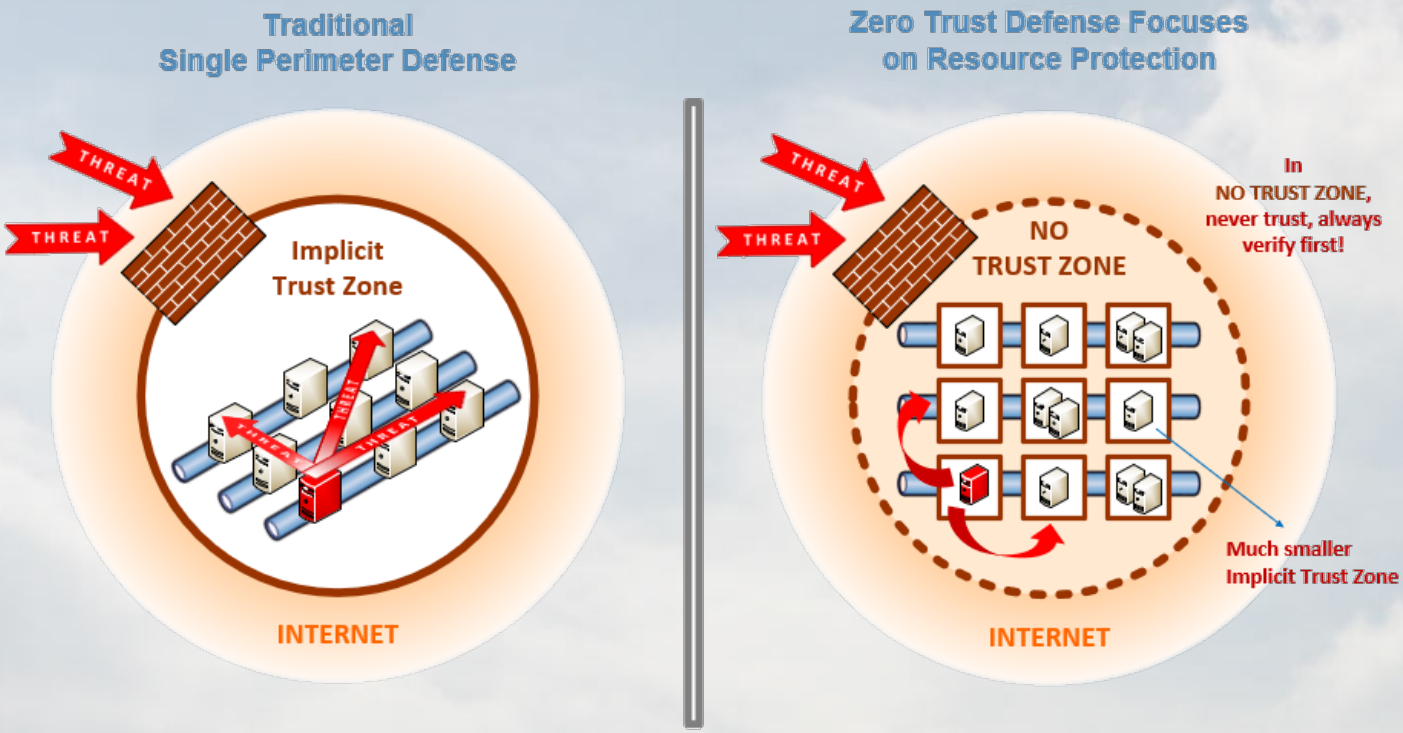
DiD: Modelo conceptual para **diseñar un sistema de seguridad en capas** o perímetros para **incrementar su fiabilidad**, para **determinar las politicas de seguridad** y para representar la **ubicación de los mecanismos de seguridad**



fuente: www.flu-project.com/2013/07/defensa-en-profundidad-ii-de-iii_1.html

en detalle

(Propuesta actual) Arquitectura de confianza cero (Zero Trust Architecture)



"Nunca confiar, siempre verificar"

Seguridad basada en un control de accesos a los recursos continuo y granular, y servicios de autenticación y autorización dinámicos

Objetivo de la seguridad: proteger los **datos** sensibles (en reposo, en tránsito, o en uso)

- Determinar qué/quién puede acceder, a qué datos, con qué permisos y desde dónde.

Principios del modelo:

- Acceso seguro y autenticado a datos, equipos, sistemas..., con independencia de su ubicación
- Adoptar la estrategia del "modelo de acceso de menor privilegio" y forzar controles de acceso estrictos
- Inspeccionar y monitorizar de forma continua y dinámica

Estándar *de facto*: Implementing a Zero Trust Architecture (NIST SP 1800-35)

